Nama : Ammar
Nim : 2024573010129
Kelas : TI3B
Matkul : Pemograman Mobile (With Flutter)

Perbedaan Publishable key, secret key, Pengertian row level security

1. Tabel Perbandingan: Publishable Key, Secret Key, dan Kunci Database Langsung

Berikut adalah perbandingan tiga jenis kunci akses pada Supabase berdasarkan konsep, tempat penulisan, kemampuan, serta boleh tidaknya disertakan di dalam aplikasi Flutter.

Kunci	Deskripsi / Konsep Utama	Ditulis di Mana	Kemampuan	Boleh di Aplikasi?
Publishable key (dulu disebut anon key)	Kunci untuk aplikasi client yang berfungsi sebagai identitas aplikasi, bukan pemberi izin penuh.	Di dalam aplikasi Flutter (dimasukkan bersama URL project ke Supabase.initialize).	Hanya sejauh yang diizinkan oleh RLS dan policy.	Ya, memang dibuat untuk aplikasi client.
Secret key (dulu disebut service_role key)	Kunci tingkat administrator yang dipakai oleh server atau backend.	Hanya di server atau backend.	Menembus RLS dan memiliki akses penuh ke data.	TIDAK PERNAH.
Kunci database langsung (password Postgres)	Kredensial untuk terhubung langsung ke database PostgreSQL.	Hanya di server.	Akses penuh ke database.	TIDAK PERNAH.

Mengapa Publishable Key Aman, tetapi Secret Key Tidak

- **Publishable key aman** karena kekuatannya dibatasi oleh RLS di dalam database. Walaupun kunci ini disalin orang lain dari aplikasi, orang tersebut hanya bisa melakukan hal yang diizinkan policy.
- **Secret key berbahaya** karena menembus RLS. Jika bocor, siapa pun yang memilikinya dapat membaca, mengubah, dan menghapus seluruh isi database.

Catatan Praktis

- Jika secret key pernah tertulis di kode aplikasi atau terunggah ke GitHub, kunci harus segera diganti (rotate) dari dashboard Supabase.
- Secret key dan password database juga tidak boleh dimasukkan ke laporan, screenshot, maupun repositori.
- Parameter inisialisasi sekarang bernama publishableKey. Parameter lama anonKey masih diterima dan merujuk hal yang sama, sehingga tutorial lama yang memakai anonKey tetap relevan.

2. Review Ringkas: Row Level Security (RLS)

A. Pengertian RLS

- **Fungsi Utama:** Row Level Security adalah mekanisme keamanan di dalam database PostgreSQL yang menentukan baris mana yang boleh dibaca atau ditulis oleh siapa.
- **Peran dalam Aplikasi:**
    - **Pengaman di dalam database, bukan di dalam aplikasi.** Jadi walaupun publishable key disalin orang lain, isi database tetap terlindungi.
    - **Aturan bawaan:** setelah RLS aktif, tidak ada baris yang boleh diakses kecuali ada policy yang mengizinkannya.
    - **Tanpa RLS,** siapa pun yang memiliki publishable key (yang ada di dalam aplikasi) dapat membaca bahkan menghapus seluruh isi tabel.
- **Catatan Praktis:** RLS bekerja bersama Data API. Aplikasi berbicara ke Data API (PostgREST), lalu RLS memeriksa setiap permintaan sebelum sampai ke tabel PostgreSQL.

B. Policy dan Peran (Role)

- **Fungsi Utama:** policy adalah aturan yang melekat pada tabel dan menentukan operasi mana (SELECT, INSERT, UPDATE, DELETE) yang diizinkan untuk peran tertentu.
- **Peran dalam Aplikasi:**
    - **anon:** pengunjung yang belum login. Dipakai pada praktikum.
    - **authenticated:** pengguna yang sudah login. Dipakai pada pertemuan berikutnya.
    - **service_role:** server, melewati RLS, hanya untuk tugas administratif.
    - **Isi policy:** klausa using menentukan baris yang boleh dilihat atau diubah, sedangkan with check menentukan baris baru yang boleh ditulis. Pada praktikum dibuat satu policy untuk tiap operasi.

- **Catatan Praktis:**
    - Selain policy RLS, Supabase versi terbaru juga memerlukan grant agar tabel dapat diakses lewat Data API. Jika hasil select() selalu kosong atau muncul permission denied, penyebab paling umum adalah grant belum dijalankan.
    - Error "new row violates row-level security policy" berarti RLS aktif tetapi policy insert belum ada.
    - Pada tabel ber-RLS, delete() hanya menghapus baris yang terlihat oleh policy SELECT. Jika policy SELECT belum ada, delete() tampak berhasil tetapi tidak menghapus apa pun dan tidak ada pesan error.

C. Policy Terbuka pada Praktikum dan Perbaikannya

- **Fungsi Utama:** policy dengan using (true) berarti seluruh dunia boleh membaca dan mengubah tabel. Ini dipakai pada praktikum karena aplikasi belum memiliki sistem login.
- **Peran dalam Aplikasi:** hanya untuk latihan dan prototipe, bukan untuk aplikasi yang sudah dipakai orang banyak. Jika dipakai banyak orang dengan policy terbuka, siapa pun bisa mengubah atau menghapus data pengguna lain.
- **Catatan Praktis:** setelah sistem login tersedia, policy dipersempit menjadi berbasis pengguna, misalnya auth.uid() = user_id, sehingga setiap pengguna hanya dapat mengubah datanya sendiri.

Kesimpulan

Publishable key aman disertakan di aplikasi karena kemampuannya dibatasi RLS, sedangkan secret key dan password database menembus perlindungan tersebut sehingga hanya boleh berada di server. RLS adalah pengaman di dalam database yang bekerja lewat policy per peran. Tiga hal yang selalu diingat: RLS adalah pengaman di dalam database, secret key tidak pernah boleh masuk aplikasi atau repositori, dan policy using (true) hanya untuk latihan.